



ZAP por Informe de Escaneo Checkmarx

prueba de seguridad de backend

Sitios: http://localhost:5173 http://127.0.0.1:8000

Generado a mar, 18 nov 2025 00:49:41

ZAP Versión: 2.16.1

ZAP by [Checkmarx](#)

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	0
Medio	2
Bajo	3
Informativo	3

Alertas

Nombre	Nivel de riesgo	Número de Instancias
Cabecera Content Security Policy (CSP) no configurada	Medio	19
Falta de cabecera Anti-Clickjacking	Medio	3
Cookie Sin Flag HttpOnly	Bajo	3
El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP	Bajo	17
Falta encabezado X-Content-Type-Options	Bajo	8
Aplicación Web Moderna	Informativo	3
Petición de Autenticación Identificada	Informativo	2
Respuesta de Gestión de Sesión Identificada	Informativo	8

Detalles de la Alerta

Medio	Cabecera Content Security Policy (CSP) no configurada
Descripción	La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web

	declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.
URL	http://127.0.0.1:8000/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/anular/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/cambiar_estado/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/cerrar/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/editar/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/evidencia/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/exportar/
Método	GET
Ataque	
Evidencia	
Otra	

información	
URL	http://127.0.0.1:8000/iniciar/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/login/?next=/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/pausar/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/reanudar/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/repuestos/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/tareas/

Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://127.0.0.1:8000/login/
Método	POST
Ataque	
Evidencia	
Otra información	
Instancia	19
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.
Referencia	https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medio	Falta de cabecera Anti-Clickjacking
Descripción	La respuesta no protege contra ataques de "ClickJacking". Debes incluir Content-Security-Policy con la directiva "frame-ancestors" o X-Frame-Options.

URL	http://localhost:5173/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	
Instancia	3
Solución	Los navegadores web modernos admiten las cabeceras HTTP Content-Security-Policy y X-Frame-Options. Asegúrese de que una de ellas está configurada en todas las páginas web devueltas por su sitio/aplicación. Si espera que la página esté enmarcada solo por páginas en su servidor (por ejemplo, si forma parte de un FRAMESET), utilice SAMEORIGIN; de lo contrario, si no espera que la página esté enmarcada, utilice DENY. Alternativamente, considere implementar la directiva "frame-ancestors" de la Política de Seguridad de Contenidos.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Bajo	Cookie Sin Flag HttpOnly
Descripción	Se ha establecido una cookie sin el flag HttpOnly, lo que significa que JavaScript puede acceder a la cookie. Si un script malicioso puede ser ejecutado en esta página, entonces la cookie será accesible y puede ser transmitida a otro sitio. Si se trata de una cookie de sesión, el secuestro de sesión puede ser posible.
URL	http://127.0.0.1:8000/
Método	GET
Ataque	
Evidencia	Set-Cookie: csrftoken
Otra información	
URL	http://127.0.0.1:8000/login/?next=/
Método	GET
Ataque	
Evidencia	Set-Cookie: csrftoken

Otra información	
URL	http://127.0.0.1:8000/login/
Método	POST
Ataque	
Evidencia	Set-Cookie: csrftoken
Otra información	
Instancia	3
Solución	Asegúrese de que la flag HttpOnly está establecida para todas las cookies.
Referencia	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Bajo	El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP
Descripción	El servidor web/aplicación está filtrando información de versión a través de la cabecera de respuesta HTTP "Server". El acceso a dicha información puede facilitar a los atacantes la identificación de otras vulnerabilidades a las que está sujeto su servidor web /aplicación.
URL	http://127.0.0.1:8000/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/anular/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/cambiar_estado/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/cerrar/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/editar/

Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/evidencia/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/exportar/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/iniciar/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/login/?next=/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/login?next=/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/pausar/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/reanudar/
Método	GET
Ataque	

Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/repuestos/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/robots.txt
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/sitemap.xml
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/tareas/
Método	GET
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
URL	http://127.0.0.1:8000/login/
Método	POST
Ataque	
Evidencia	WSGIServer/0.2 CPython/3.14.0
Otra información	
Instancia	17
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. está configurado para suprimir la cabecera "Server" o proporcionar detalles genéricos.
Referencia	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Bajo	Falta encabezado X-Content-Type-Options
	La cabecera Anti-MIME-Sniffing X-Content-Type-Options no se ha establecido en 'nosniff'. Esto permite que las versiones anteriores de Internet Explorer y Chrome realicen

Descripción	MIME-sniffing en el cuerpo de la respuesta, lo que puede provocar que el cuerpo de la respuesta se interprete y se muestre como un tipo de contenido distinto del tipo de contenido declarado. Las versiones actuales (principios de 2014) y heredadas de Firefox utilizarán el tipo de contenido declarado (si se establece uno), en lugar de realizar MIME-sniffing.
URL	http://localhost:5173/
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/@id/virtual:vue-devtools-path:overlay.js
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/@id/virtual:vue-inspector-path:load.js
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/@vite/client
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/favicon.ico
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/robots.txt

Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/src/main.js
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
Instancia	8
Solución	Asegúrese de que la aplicación/servidor web establece el encabezado Content-Type adecuadamente, y que establece el encabezado X-Content-Type-Options a 'nosniff' para todas las páginas web. Si es posible, asegúrese de que el usuario final utiliza un navegador web moderno y compatible con los estándares que no realiza MIME-sniffing en absoluto, o que puede ser dirigido por la aplicación web/servidor web para que no realice MIME-sniffing.
Referencia	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informativo	Aplicación Web Moderna
Descripción	La aplicación parece ser una aplicación web moderna. Si necesita explorarla automáticamente, el Ajax Spider puede ser más eficaz que el estándar.
URL	http://localhost:5173/
Método	GET
Ataque	
Evidencia	<script type="module" src="/@id/virtual:vue-devtools-path:overlay.js"></script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:5173/robots.txt

Método	GET
Ataque	
Evidencia	<script type="module" src="/@id/virtual:vue-devtools-path:overlay.js"></script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	<script type="module" src="/@id/virtual:vue-devtools-path:overlay.js"></script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
Instancia	3
Solución	Se trata de una alerta informativa, por lo que no es necesario realizar ningún cambio.
Referencia	
CWE Id	
WASC Id	
Plugin Id	10109

Informativo	Petición de Autenticación Identificada
Descripción	La petición en cuestión se ha identificado como una petición de autenticación. El campo "Otra información" contiene un conjunto de líneas key=value que identifican cualquier campo relevante. Si la solicitud está en un contexto que tiene un método de autenticación configurado como "Detección automática", esta regla cambiará la autenticación para que coincida con la petición identificada.
URL	http://127.0.0.1:8000/login/
Método	POST
Ataque	
Evidencia	password
Otra información	userParam=username userValue=ZAP passwordParam=password referer=http://127.0.0.1:8000/login/ csrfToken=csrfmiddlewaretoken
URL	http://127.0.0.1:8000/login/
Método	POST
Ataque	
Evidencia	password
Otra información	userParam=username userValue=ZAP passwordParam=password referer=http://127.0.0.1:8000/login/?next=/ csrfToken=csrfmiddlewaretoken
Instancia	2
Solución	Se trata de una alerta informativa y no de una vulnerabilidad, por lo que no hay nada que corregir.
Referencia	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informativo	Respuesta de Gestión de Sesión Identificada
	Se ha identificado que la respuesta dada contiene un token de gestión de sesión. El campo 'Other Info' contiene un conjunto de tokens de cabecera que pueden utilizarse en

Descripción	el método Header Based Session Management (gestión de sesión basado en cabecera). Si la petición se encuentra en un contexto que tiene un método Session Management establecido en "Auto-Detect", esta regla cambiará la gestión de sesión para utilizar los tokens identificados.
URL	http://127.0.0.1:8000/
Método	GET
Ataque	
Evidencia	I0aX8B2J1O98XnlZ8jszbDDnO0cJlVQ3
Otra información	cookie:csrftoken
URL	http://127.0.0.1:8000/
Método	GET
Ataque	
Evidencia	MhL8Bz7PkTWWZaDz6YZxz1ho6URAgilD
Otra información	cookie:csrftoken
URL	http://127.0.0.1:8000/login/?next=/
Método	GET
Ataque	
Evidencia	eWjriurD8IRBcZax8GgdGHlTY56PbKzG
Otra información	cookie:csrftoken
URL	http://127.0.0.1:8000/login/?next=/
Método	GET
Ataque	
Evidencia	Ig6g2IRfSKTthiyOgZ0O8EN5iG6ELKdF
Otra información	cookie:csrftoken
URL	http://127.0.0.1:8000/login/
Método	POST
Ataque	
Evidencia	eWjriurD8IRBcZax8GgdGHlTY56PbKzG
Otra información	cookie:csrftoken
URL	http://127.0.0.1:8000/login/
Método	POST
Ataque	
Evidencia	Ig6g2IRfSKTthiyOgZ0O8EN5iG6ELKdF
Otra información	cookie:csrftoken
URL	http://127.0.0.1:8000/login/
Método	GET
Ataque	
Evidencia	Ig6g2IRfSKTthiyOgZ0O8EN5iG6ELKdF

Otra información	cookie:csrftoken
URL	http://127.0.0.1:8000/login/?next=/
Método	GET
Ataque	
Evidencia	eWjriurD8IRBcZax8GgdGHLTY56PbKzG
Otra información	cookie:csrftoken
Instancia	8
Solución	Se trata de una alerta informativa y no de una vulnerabilidad, por lo que no hay nada que corregir.
Referencia	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id
CWE Id	
WASC Id	
Plugin Id	10112